REPUBLIQUE DU CAMEROUN

Paix – Travail – Patrie

MINISTERE DE L'ENSEIGNEMENT SUPERIEUR

UNIVERSITE DE YAOUNDE I

ECOLE NATIONALE SUPERIEURE POLYTECHNIQUE DE YAOUNDE

DEPARTEMENT DE GENIE INFORMATIQUE

REPUBLIC OF CAMEROON

Peace – Work – Fatherland

MINISTRY OF HIGHER EDUCATION

UNIVERSITY OF YAOUNDE I

NATIONAL ADVANCED SCHOOL OF ENGINEERING

COMPUTER ENGINEERING DEPARTMENT

Matière : **GES4062 - ANALYSE DE RISQUE, AUDIT ET GESTION DE CRISE**

RAPPORT DE LA CHARTE DE GOUVERNANCE ET MATRICE RACI

ENTREPRISE LIZBIZ

Réalisé par :

Noms et Prénoms	Matricule	Filière
OWONO OWONO MARTIN	22P099	MSI-4

Sous la supervision de :

M. Thierry MINKA

ANNÉE ACADÉMIQUE : 2025 / 2026

Table des matières

1 Charte de Gouvernance du RSSI **3**

1.1 Article 1 - Positionnement dans l'organisation . . . 3
1.2 Article 2 - Missions . . . 3
1.3 Article 3 - Pouvoirs décisionnels . . . 4
1.4 Article 4 - Responsabilités . . . 5
1.5 Article 5 - Moyens alloués . . . 5
1.6 Article 6 - Approbation et entrée en vigueur . . . 5

2 Matrice RACI - Gestion des Incidents Critiques **7**

2.1 Légende . . . 7
2.2 Acteurs . . . 7
2.3 Incident 1 - Attaque Ransomware CRITIQUE (M1) . . . 7
2.4 Incident 2 - Fuite de données clients CRITIQUE (M2 / RGPD) . . . 8
2.5 Incident 3 - Compromission réseau / pivot inter-VLAN ÉLEVÉ (M3) . . . 8
2.6 Incident 4 - Compromission équipements IoT ÉLEVÉ (M4) . . . 9
2.7 Incident 5 - Accès frauduleux ERP / ancien employé ÉLEVÉ (M5) . . . 9
2.8 Incident 6 - Non-conformité réglementaire (M8) . . . 9

Glossaire des abréviations **11**

1 Charte de Gouvernance du RSSI

■ Cas Pratique - Entreprise LiZbiZ

Mission : Pour le prochain Comité de Direction, vous devez proposer une **charte de gouvernance** simple. Elle doit définir clairement le rôle du futur RSSI et mettre en place un RACI pour la gestion des incidents critiques.

■ Contexte et justification

Suite à une croissance rapide, le poste de **RSSI** est resté vacant chez **LiZbiZ**. Cette absence a conduit à des vulnérabilités documentées : patchs irréguliers, absence de PCA, droits d'accès non révoqués. La cotation en bourse récente renforce l'urgence de formaliser ce rôle avant tout incident majeur aux conséquences réputationnelles et financières irréversibles.

1.1 Article 1 - Positionnement dans l'organisation

Rattachement hiérarchique. Le RSSI est rattaché à la Direction des Systèmes d'Information (DSI). Il rend compte directement à la DSI pour toutes les décisions opérationnelles et stratégiques du quotidien.

Accès direct au PDG en crise. En situation de crise avérée - incident de sécurité critique, violation de données, attaque en cours - le RSSI dispose d'un droit d'accès direct et immédiat au PDG, *sans nécessité de validation hiérarchique intermédiaire*. Ce droit est activé selon les critères définis dans la Partie 2 (RACI).

★ Justification du double rattachement

Le rattachement DSI garantit l'ancrage stratégique et la cohérence avec la politique IT au quotidien. L'accès direct PDG en crise évite tout blocage hiérarchique quand chaque minute compte - notamment face à une attaque ransomware ou une violation de données soumise à notification CNIL sous 72 heures.

Profil du poste. **RSSI gouvernance** - le titulaire assure exclusivement le pilotage stratégique de la sécurité : définition de la politique, gestion des risques, conformité réglementaire et coordination des acteurs. La supervision technique est déléguée à l'équipe IT sous son autorité fonctionnelle.

1.2 Article 2 - Missions

Le RSSI LiZbiZ est titulaire des six missions permanentes suivantes :

N°	Mission	Description et périmètre
M1	**Politique de Sécurité (PSSI)**	Rédiger, maintenir et faire approuver la Politique de Sécurité des SI. S'assurer de son application. Révision annuelle obligatoire.
M2	**Gestion des incidents et crises**	Piloter la détection, la qualification, la réponse et la communication. Coordonner le déclenchement du PCA. Rôle central dans la matrice RACI.
M3	**Audits et contrôles internes**	Planifier et conduire des audits de sécurité réguliers (réseau, applicatifs, accès). Produire des rapports de conformité à la direction.
M4	**Conformité réglementaire**	Assurer la conformité RGPD, PCI-DSS niveau 1 et LPM/OIV. Coordonner avec le DPO et les auditeurs externes.
M5	**Sensibilisation et formation**	Concevoir et déployer un programme de sensibilisation pour les 150 salariés. Priorité au phishing et aux bonnes pratiques d'accès.
M6	**Pilotage de la gouvernance sécurité**	Coordonner les acteurs sécurité. Produire les tableaux de bord pour le Comité de Direction. Déléguer l'exécution technique à l'équipe IT.

1.3 Article 3 - Pouvoirs décisionnels

Le RSSI dispose des pouvoirs suivants, exerçables en autonomie complète, sans validation préalable :

Pouvoir	Périmètre	Condition d'exercice
Bloquer un service ou système en cas de menace imminente	Tout le SI	Menace avérée - notification DSI dans l'heure.
Valider ou bloquer tout projet IT avant mise en production	Projets IT	Avis sécurité obligatoire - veto soumis à arbitrage DSI/PDG.
Déclencher le PCA sans accord préalable	SI complet	Incident critique qualifié - information PDG immédiate.
Imposer un audit à n'importe quel département	Tous	Programme annuel approuvé par DSI - audits ad hoc sur justification.
Refuser un fournisseur pour raison de sécurité	Achats IT	Avis motivé écrit - recours possible auprès du DAF.

★ Limite des pouvoirs - principe de proportionnalité

Les décisions à impact financier majeur restent soumises à validation conjointe DSI + DAF. Le RSSI propose, arbitre en urgence opérationnelle, mais n'engage pas de dépenses significatives de façon unilatérale.

1.4 Article 4 - Responsabilités

Le RSSI est responsable devant la DSI et le Comité de Direction des éléments suivants :

- Tout incident de sécurité non signalé dans les délais impartis (72 heures pour violations RGPD).
- Toute non-conformité réglementaire non remontée au Comité de Direction.
- Tout projet IT mis en production sans avis de sécurité formalisé.
- L'exactitude et l'exhaustivité des rapports d'audit transmis à la direction.
- La mise à jour effective du PCA après chaque incident ou exercice de crise.

Clause de bonne foi

La responsabilité du RSSI ne peut être engagée pour des incidents résultant de décisions prises *contre son avis écrit et documenté*, ou en l'absence de moyens adéquats formellement refusés par la direction.

1.5 Article 5 - Moyens alloués

Ressource	Détail
Budget sécurité	Enveloppe annuelle à valider par le DAF - usage : outils, audits externes, formations.
Accès systèmes	Accès en lecture à l'intégralité du SI - journaux des équipements de sécurité (firewall, SIEM) sans intervention directe.
Équipe IT	Supervision fonctionnelle de 2 techniciens IT.
Outils	SIEM (à déployer), scanner de vulnérabilités (Nessus ou équivalent), GNS3.
Reporting	Rapport mensuel DSI - rapport trimestriel Comité - rapport annuel PSSI.

1.6 Article 6 - Approbation et entrée en vigueur

La présente charte entre en vigueur à la date de sa signature par le PDG et la DSI. Elle est révisée annuellement ou après tout incident majeur.

PDG - Jean-Pierre L.	**DSI - Sophie M.**	**RSSI - Futur titulaire**
_____	_____	_____
Date : _____	Date : _____	Date : _____

2 Matrice RACI - Gestion des Incidents Critiques

2.1 Légende

Code	Rôle	Définition
R	**Responsible**	Réalise l'action. Exécution opérationnelle de la tâche.
A	**Accountable**	Autorité finale. Valide et assume la responsabilité. **Un seul A par tâche.**
C	**Consulted**	Consulté avant la décision. Apporte une expertise. Communication bidirectionnelle.
I	**Informed**	Informé après la décision. Communication unidirectionnelle.

2.2 Acteurs

Acteur	Poste	Rôle dans la gestion de crise
PDG	Jean-Pierre L.	Décision finale, communication externe (presse, bourse).
DSI	Sophie M.	Pilotage stratégique, arbitrage des ressources.
RSSI	Futur titulaire	Coordination sécurité, qualification, déclenchement PCA.
DAF	Dir. Financier	Validation coûts de crise, communication financière.
R. Log.	Resp. Log.	Incidents IoT et entrepôt, équipes terrain.
Eq. IT	Techniciens	Exécution technique des actions de remédiation.

➤ Source des incidents

Les 6 incidents couverts sont issus des menaces M1 à M5 et M8, de **la mission d'audit et d'analyse des risques**.

2.3 Incident 1 - Attaque Ransomware CRITIQUE (M1)

Tâche / Action	PDG	DSI	RSSI	DAF	R.Log.	Eq. IT
Incident 1 - Attaque Ransomware (M1) CRITIQUE						
Détection et qualification de l'attaque	I	C	R/A	–	–	C

suite...

Tâche / Action (suite)	PDG	DSI	RSSI	DAF	R.Log.	Eq. IT
Isolation des systèmes infectés	–	A	R	–	C	R
Déclenchement du PCA	A	C	R	C	I	I
Communication externe (presse / bourse)	R/A	C	C	C	–	–
Restauration depuis sauvegardes NAS	–	A	C	–	–	R
Rapport post-incident et corrections	I	A	R	I	C	C

2.4 Incident 2 - Fuite de données clients CRITIQUE (M2 / RGPD)

Tâche / Action	PDG	DSI	RSSI	DAF	R.Log.	Eq. IT
Incident 2 - Fuite de données clients (M2 / RGPD) CRITIQUE						
Détection et analyse de la violation	–	C	R/A	–	–	R
Notification CNIL (72h réglementaires)	A	C	R	C	–	–
Communication aux clients impactés	A	C	R	C	–	–
Colmatage de la vulnérabilité Magento	–	A	C	–	–	R
Évaluation du préjudice financier	A	C	C	R	–	–

2.5 Incident 3 - Compromission réseau / pivot inter-VLAN ÉLEVÉ (M3)

Tâche / Action	PDG	DSI	RSSI	DAF	R.Log.	Eq. IT
Incident 3 - Compromission réseau / pivot inter-VLAN (M3) ÉLEVÉ						
Détection du mouvement latéral	–	C	R/A	–	–	R
Blocage des flux inter-VLANs suspects	–	A	R	–	–	R
Analyse forensique du firewall	–	C	R/A	–	–	C

suite...

Tâche / Action (suite)	PDG	DSI	RSSI	DAF	R.Log.	Eq. IT
Remédiation et durcissement règles FW	–	A	R	–	–	R

2.6 Incident 4 - Compromission équipements IoT ÉLEVÉ (M4)

Tâche / Action	PDG	DSI	RSSI	DAF	R.Log.	Eq. IT
Incident 4 - Compromission équipements IoT (M4) ÉLEVÉ						
Détection anomalie sur VLAN 40	–	C	R/A	–	C	R
Isolation du VLAN 40 du reste du SI	–	A	R	–	C	R
Gestion entrepôt en mode dégradé	I	C	C	I	R/A	–
Remédiation et réinitialisation scanners RFID	–	A	C	–	R	R

2.7 Incident 5 - Accès frauduleux ERP / ancien employé ÉLEVÉ (M5)

Tâche / Action	PDG	DSI	RSSI	DAF	R.Log.	Eq. IT
Incident 5 - Accès frauduleux ERP / ancien employé (M5) ÉLEVÉ						
Détection accès anormal sur Odoo	–	C	R/A	–	–	R
Révocation immédiate du compte	–	A	R	–	–	R
Analyse des données consultées	–	C	R/A	C	–	C
Dépôt de plainte et aspects juridiques	A	C	C	R	–	–

2.8 Incident 6 - Non-conformité réglementaire (M8)

Tâche / Action	PDG	DSI	RSSI	DAF	R.Log.	Eq. IT
Incident 6 - Non-conformité réglementaire (M8)						
Identification de la non-conformité	–	C	R/A	C	–	–
Élaboration du plan de remédiation	A	C	R	C	–	C
Communication aux autorités (CNIL, auditeur PCI)	A	C	R	R	–	–
Mise en oeuvre des corrections techniques	–	A	C	–	–	R
Suivi et clôture de la non-conformité	I	C	R/A	I	–	C

Note de lecture

- **R/A** : le RSSI est à la fois *Responsible* (pilote) et *Accountable* (garant) sur certaines tâches de coordination. L'exécution technique est systématiquement confiée à l'équipe IT.
- Ce positionnement garantit la séparation entre pilotage stratégique et exécution opérationnelle.
- Chaque incident fait l'objet d'un **rapport post-mortem** transmis au Comité de Direction sous **5 jours ouvrés**.

Glossaire des abréviations

■ Abréviations utilisées dans ce document

Les sigles et abréviations ci-dessous sont classés par ordre alphabétique.

Sigle	Développement	Définition
CNIL	**Commission Nationale de l'Informatique et des Libertés**	Autorité française de contrôle de la protection des données.
DAF	**Directeur des Affaires et Financière**	Responsable de la gestion financière de l'entreprise.
DMZ	**DeMilitarized Zone**	Segment réseau isolé hébergeant les services accessibles depuis Internet.
DPO	**Data Protection Officer**	Délégué à la Protection des Données, responsable de la conformité RGPD.
DSI	**Direction des Systèmes d'Information**	Responsable de toute l'infrastructure informatique.
ERP	**Enterprise Resource Planning**	Progiciel intégrant les processus métiers (stocks, ventes, comptabilité).
FW / Firewall	**Pare-feu**	Dispositif de filtrage des flux réseau.
IoT	**Internet of Things**	Équipements connectés non conventionnels (scanners, capteurs, automates).
LPM	**Loi de Programmation Militaire**	Loi imposant des obligations aux Opérateurs d'Importance Vitale.
NAS	**Network Attached Storage**	Système de stockage en réseau pour les sauvegardes.
OIV	**Opérateur d'Importance Vitale**	Organisme dont l'activité est critique pour la nation.
PCA	**Plan de Continuité d'Activité**	Procédures pour maintenir l'activité après sinistre.
PCI-DSS	**Payment Card Industry Data Security Standard**	Norme de sécurité pour les paiements par carte.
PDG	**Président-Directeur Général**	Dirigeant exécutif, détenteur de l'autorité finale.
PRA	**Plan de Reprise d'Activité**	Composante du PCA dédiée à la restauration du SI.
PSSI	**Politique de Sécurité des SI**	Document cadre définissant les objectifs de sécurité.

suite...

Sigle (suite)	Développement	Définition
RACI	**Responsible, Accountable, Consulted, Informed**	Matrice de répartition des rôles et responsabilités.
RFID	**Radio Frequency Identification**	Identification automatique par ondes radio (traçage logistique).
RGPD	**Règlement Général sur la Protection des Données**	Règlement européen (2016/679) sur les données personnelles.
RPO	**Recovery Point Objective**	Perte de données maximale tolérée après incident.
RSSI	**Responsable Sécurité des Systèmes d'Information**	Pilote la politique de sécurité informatique.
RTO	**Recovery Time Objective**	Durée maximale d'interruption tolérée après incident.
SIEM	**Security Information and Event Management**	Système centralisant les événements de sécurité pour analyse en temps réel.
VLAN	**Virtual Local Area Network**	Réseau local virtuel permettant la segmentation logique.

Ce document constitue la livraison du Travail Pratique - Première Mission (section 3.4.3 du document du cours)
Mission de sécurisation de l'entreprise LiZbiZ - UE : GES4062

Travail supervisé par M. Thierry MINKA
Année 2025 / 2026